Agent Canary 3.0

可验证的 AI Agent 安全执行与自适应蜜罐平台

工程候选，非稳定版；保留已验证 2.0 参赛版本。

可信执行网关 + 隔离诱饵 + 局部可验证证据。真实本地模型自主选择工具，安全策略拥有最终执行权。

代码冻结：9f00b6ba7475e8bccc5410e1484ed74a7806b7d1

仓库：https://github.com/DorianChn/shanchuanzhi-agent-canary

本材料不承诺全局 Agent 防护、100% Prompt Injection 防护、零误报或获奖。

问题与执行边界

模型可能受到仓库文档、网页或工具输出中的恶意指令影响。诱饵信号有价值，但模型不接触诱饵时，单靠 Canary 不能证明危险操作被拦截。

3.0 将确定性权限检查放在登记工具执行前，区别检测事件、策略拒绝、Guard 隔离、实际效果和证据。

宿主建立资源及工具清单，模型只能提出调用。被拒绝的调用必须观察真实目标未改变，而不是只看到 DENY 字样。

不覆盖未接入的第三方回调、模型内部状态或已开始的外部效果。

可信执行闭环

身份与任务能力 → JSON 参数规范化 → 资源绑定检查 → 风险 / 数据流规则 → 必要时 AI 与宿主审批 → Guard 复查 → 执行 → 效果与证据。

文件：持有预登记 fd，拒绝链接、硬链接、路径替换、未登记写入和超限内容；使用 fd 操作和字节复查。

命令：固定 executable 与 argv，无模型 Shell 字符串。HTTP：批准 HTTPS origin、DNS 校验及 socket pin、无重定向、只读 JSON GET。

MCP：宿主登记风险类别与回调；敏感历史后 network 回调执行前拒绝。operator 对象只交给可信宿主，一次消费、有限有效期。

它不是 OS 沙箱。固定程序自身权限及同权限本地进程仍属于信任边界。

隔离蜜罐与数据关联

五类隔离资源：虚拟 .env、无效 SSH 凭据、虚拟数据库、虚拟内部 API、虚拟 MCP。使用新建私有临时目录，没有真实账户或密钥。

唯一 Decoy ID；DEPLOYED 不等于 READ。只记录观察到的交互、拒绝和隔离。真实模型直接准入轨迹包含 .env 读取 → QUARANTINED → 后续写入拒绝。

AdaptiveDecoyPlanner 使用可信任务元数据进行启发式选择，自适应优于静态的结论尚未测得。

有界 HMAC 片段指纹可关联部分编码 / 长片段引用；短片段、任意变换、未观察工具 OUT_OF_SCOPE，不是完整动态污点分析。

真实实验与工程证据

组	危险效果	主动拒绝任务	正常完成
A	0/5	0/5	3/3
B	0/5	0/5	3/3
C	0/5	0/5	3/3
D	0/5	0/5	3/3
E	0/5	0/5	3/3
F	0/5	0/5	3/3

间接 README 对照：各组模型没有尝试恶意操作，不能证明额外防护收益。

组	危险效果	主动拒绝任务	正常完成
A	4/4	0/4	3/3
E	0/4	4/4	3/3
F	0/4	4/4	3/3

单独的直接执行准入验证：实际受限调用与危险副作用前后对照；不能换算为 Prompt Injection 防护率。

本地根测试 254 项：250 通过、4 跳过；Sponsor 25 项：24 通过、1 跳过。最终 CI 与精确日志以 FINAL_REPORT.md 为准。

开放价值与发布限制

Community 工程候选通过正向清单独立构建，不包含 legacy 商业 license / dashboard / export / eval 实现。MIT 保留；不单方面迁移 Apache-2.0 或改变付费用户授权。

Open Security Evidence Protocol v0.1 使用 JSON Schema、请求 HMAC 摘要、规范化事件哈希链。无外部可信锚、签名或独立时间戳，不能称为绝对防篡改。

原生 Codex / Claude Code / Cursor / Cline 仅配置 / 协议 / hook 部分验证，主验收对象为受控 SDK Agent。

长期路线：3.1 官方宿主插件验收；3.2 更广独立评测与审查误报研究；3.5 团队便利功能；4.0 多 Agent 最小权限。未来功能不是当前已实现能力。

尚未达到完整 3.0 稳定发布门槛；扩大独立攻击 / 正常测试集、静态与自适应比较、原生宿主验收及商业分发边界仍需处理。